Glittercity OST1 — le chant caché dans la musique

Starpwn CTF 2026 · DEF CON 34 · Aerospace Village · auteur : Visionspace

Catégorie : Space Communications & RF **RÉSOLU — 19 août 2026**

Une chanson qui cache son jeu

Une bande-son de synthétiseur, dans le genre synthwave. Rien d'anormal à l'écoute. Mais les **métadonnées ID3** du fichier — les étiquettes collées dans le MP3 : titre, artiste, commentaires — sont bavardes. Le titre est « Capture-7 », l'artiste « PRISMANTIR », et surtout un commentaire contient un **TLE** pour un satellite baptisé CHANDELIER-7.

```
TXXX:comment =
  TLE:
  CHANDELIER-7
  1 25544U 98067A   26207.41084145  .00010751  00000+0  20166-3 0  9995
  2 25544  51.6317 105.9876 0006941 339.4731  20.5977 15.49181604577830
```

Le TLE, ou la carte d'identité orbitale d'un satellite

Un TLE (Two-Line Element, « jeu d'éléments sur deux lignes ») est le format standard pour décrire l'orbite d'un satellite : deux lignes de 69 caractères qui encodent son inclinaison, son excentricité, sa période... Avec un TLE et un propagateur (le logiciel standard s'appelle **SGP4**), on peut calculer où se trouve le satellite à tout instant. Chaque satellite catalogué a aussi un **numéro NORAD**, un identifiant à 5 chiffres attribué par le commandement de la défense spatiale américain, qui traque tout ce qui tourne autour de la Terre.

Et justement : le numéro gravé dans ce TLE, **25544**, est le numéro NORAD le plus célèbre du monde — c'est celui de la **Station spatiale internationale**. Le nom « CHANDELIER-7 » est un déguisement posé sur l'orbite de l'ISS.

45 minutes à poursuivre la mauvaise station

Ce TLE a coûté trois quarts d'heure, et il mérite d'être raconté honnêtement. Un TLE, ça se propage : les éléments ont été chargés dans SGP4, les positions calculées minute par minute, l'altitude vérifiée (~415 km), et la possibilité d'une géolocalisation de la station sol par Doppler sérieusement envisagée. Tout ça est faisable, tout ça est élégant — et tout ça est vide.

Deux raisons. D'abord, l'orbite est celle de l'ISS, donc elle ne dit rien de CHANDELIER-7. Ensuite, et c'est le point le plus important de tout ce write-up : le critère « l'altitude ressort vers 415 km » **ne pouvait pas échouer** — l'ISS est à 415 km à tout instant, quoi qu'on fasse. Or un test qui ne peut pas échouer ne prouve rien : c'est de la fausse confiance en barre. Le message n'est pas dans la trajectoire, il est dans le son. Bilan : 45 minutes de propagation orbitale pour apprendre à ignorer la plus belle donnée du fichier. Le TLE retourne dans sa boîte, le MP3 s'ouvre dans numpy.

Le vieux truc du karaoké (le canal L-R)

Concept — Cacher un signal dans la différence stéréo. Un fichier stéréo contient deux pistes : gauche (L) et droite (R). Quand on écoute en mono — ou qu'un son est « au centre » du mix —, les deux pistes sont **additionnées** : ce qui est identique des deux côtés ressort deux fois plus fort.

Maintenant, glissons un signal **en opposition de phase** : identique à gauche, mais inversé à droite (chaque montée devient une descente). Dans la somme L+R, ce signal s'annule

parfaitement — +1 + (-1) = 0 — et devient inaudible. C'est d'ailleurs le principe de certains logiciels de karaoké, qui « suppriment la voix » en soustrayant les deux canaux. Mais dans la **différence L-R**, c'est l'inverse : le signal caché s'additionne (+1 - (-1) = 2), tandis que la musique, largement commune aux deux canaux, s'efface.

C'est la stéganographie audio la plus classique, et le premier réflexe à avoir devant un fichier stéréo dans un CTF. Une ligne suffit : `d = L - R`.

La comparaison tranche : dans la bande 8–15 kHz (les aigus, là où la musique synthwave est discrète), on mesure pour chaque fenêtre de 50 ms la hauteur du pic spectral au-dessus du plancher local. Dans L+R, rien ne dépasse ~18 dB ; dans L-R, un pic étroit culmine à plus de 30 dB au-dessus du plancher, quasiment en continu entre t≈5 et 100 s — la signature d'un signal tonal persistant que la somme laisse noyé dans la musique. Quelque chose est caché là, et c'est gros.

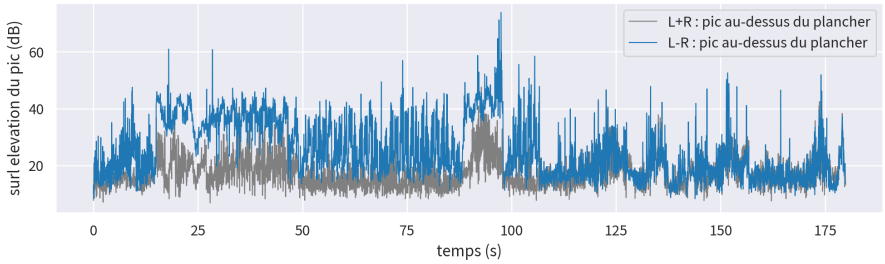


Figure 1 — Hauteur du pic spectral (8-15 kHz) au-dessus du plancher local, par fenetres de 50 ms : en L-R (bleu), un pic tonal persistant a ~30 dB sur toute la salve ; en L+R (gris), ~18 dB seulement.

Voir le son (étape 1 : le spectrogramme)

Concept — Le spectrogramme, la partition du signal. Un spectrogramme est une image où l'axe horizontal est le temps, l'axe vertical la fréquence, et la couleur la puissance. C'est l'outil de base de toute analyse de signal : on y « voit » le son comme sur une partition de piano — une note tenue dessine une ligne horizontale, une note qui glisse dessine une pente.

Le spectrogramme du canal L-R montre **deux raies parallèles**, séparées d'environ 2 kHz, qui glissent régulièrement de ~14,2/12,2 kHz vers ~10/8 kHz sur une seule longue salve de 90 secondes.

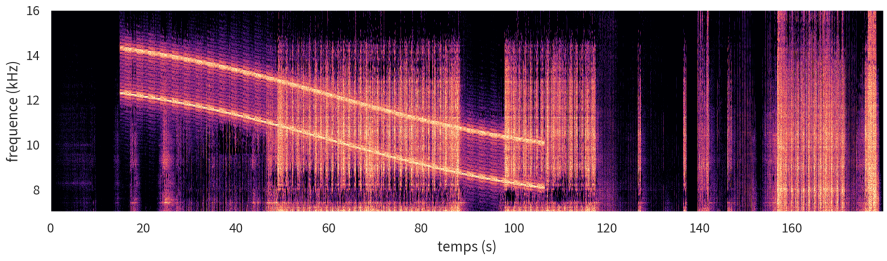


Figure 2 — Spectrogramme de L-R : deux raies paralleles (le FSK) qui glissent regulierement de ~14,2/12,2 kHz vers ~10/8 kHz — la signature Doppler du passage.

Trois faits se lisent directement sur cette image, sans rien décoder :

- **Deux tons en alternance, à écart constant** : c'est du **FSK** (Frequency-Shift Keying), la modulation la plus simple qui soit — un sifflement aigu pour le 1, un sifflement grave pour le 0 (ou l'inverse), comme un bijoutier qui coderait en alternant deux diapasons.
- **Les deux raies glissent vers le bas régulièrement** : c'est une signature **Doppler**. Même phénomène que la sirène d'ambulance qui descend quand elle s'éloigne : un émetteur qui

s'approche est entendu plus haut, un émetteur qui s'éloigne plus bas. Le glissement continu trahit un satellite qui passe au-dessus de la station et s'éloigne pendant toute sa fenêtre.

- **Une seule salve, longue et continue** — contrairement à OST2 (le morceau suivant du même album, traité dans un autre post), qui en contient quatre.

L'ambulance et les deux diapasons (étape 2 : Doppler + FSK)

Concept — Déchirper puis décider. Comme un seul ton est actif à la fois, la fréquence instantanée du signal suit une ligne de base qui dérive lentement (le Doppler), sur laquelle se superpose un petit saut haut/bas (le bit FSK). Il faut séparer les deux étages de la fusée : d'abord mesurer et retirer la dérive — c'est le **déchirpage** — puis décider bit par bit si le ton résiduel est haut ou bas.

Concrètement : une **médiane glissante** sur plusieurs symboles capture la dérive Doppler (la médiane ignore les sauts rapides, donc elle suit la tendance lente) ; ce qui reste après soustraction est le saut FSK, dont le signe donne le bit. Le débit se mesure sur les durées des symboles : **300 bauds**, c'est-à-dire 300 symboles (ici, 300 bits) par seconde — le débit typique des vieilles liaisons satellite et des modems d'antan.

20 minutes de charabia (étape 2 bis : les conventions de bits)

Le flux démodulé ne disait rien. Explication : un même flux de bits peut être **lu de plusieurs façons** selon des conventions arbitraires — les bits sont-ils inversés (1 = 0 et 0 = 1) ? les octets s'assemblent-ils poids faible d'abord (LSB first) ou poids fort d'abord (MSB first) ? Se tromper sur un seul choix transforme tout le texte en charabia. Vingt minutes supplémentaires sont parties à tester les combinaisons une par une jusqu'à ce que du texte émerge. La bonne : **bits inversés, octets poids faible d'abord**. Ce tâtonnement est exactement ce que la salve témoin d'OST2 permettra d'éviter : un morceau du signal dont on connaît la réponse fixe la convention une fois pour toutes.

Les tickets de caisse du signal (étape 3 : le HDLC)

Concept — HDLC : fanions et bit stuffing. Le flux de bits n'est pas du texte brut : il est découpé en **trames** par le protocole HDLC, un standard des années 70 toujours utilisé dans les liaisons satellite. Chaque trame est encadrée par un motif-balise appelé **fanion** : `01111110` (0x7E) — l'équivalent des lignes pointillées entre deux tickets. Problème : que se passe-t-il si les données elles-mêmes contiennent six 1 de suite, qui ressemblerait à un fanion ? Réponse du protocole, le **bit stuffing** : l'émetteur insère artificiellement un 0 après toute suite de cinq 1 consécutifs ; le récepteur, lui, retire ce 0. Le fanion ne peut donc jamais apparaître par accident dans les données. La procédure complète : repérer les fanions, découper entre eux, « dé-stuffer », lire les octets.

Chaque trame décodée contient le même message :

```
CHANDELIER-7
FLAG=STARPWN{...}
```

Le corps du flag tient en quatre mots séparés par des tirets bas — sa lecture exacte est gardée pour la fin. Et ce message est répété trame après trame pendant toute la salve. Cette redondance n'est pas décorative : c'est le mécanisme de validation du challenge.

La force du nombre (étape 4 : la redondance comme preuve)

La démodulation n'est jamais parfaite : sur une transmission Doppler bruitée, quelques bits sont lus de travers ici ou là. Prise isolément, une trame peut donner `Syn7k` ou `fr2m` au lieu du bon texte. Mais les erreurs tombent à des **endroits différents** d'une copie à l'autre — le bruit n'a pas de mémoire. Un simple **vote majoritaire**, caractère par caractère, sur les dizaines de copies successives efface le bruit : à chaque position, le bon caractère est majoritaire, donc il gagne.

Le flag validé sort de ce consensus, et non d'une seule lecture chanceuse :

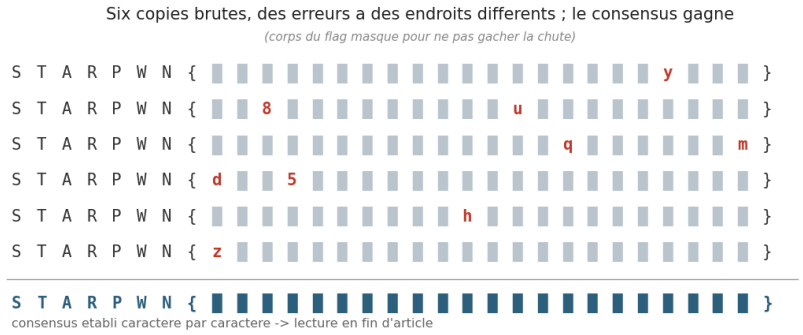


Figure 3 — Six copies brutes du flag (corps masque jusqu'au denouement) : les caracteres en rouge sont des erreurs de demodulation, a des positions differentes selon la copie. Le vote majoritaire reconstitue le flag exact.

Deux détails à retenir pour la saisie finale : le corps est en leet speak — des chiffres et un symbole déguisés en lettres — et le préfixe reste en capitales.

La morale de l'histoire

- **Un critère de validation doit pouvoir échouer** : « l'altitude ressort vers 415 km » ne pouvait pas échouer avec l'ISS — c'était de la fausse confiance à 45 minutes. Le vrai message était dans la modulation, pas dans la trajectoire.
- **Devant un fichier stéréo, regarder L-R d'abord** : c'est là que se cachent les signaux en opposition de phase, inaudibles en écoute normale.
- **Mesurer la modulation plutôt que la deviner** : deux tons -> FSK ; glissement régulier -> Doppler ; durées des symboles -> 300 bauds. Le spectrogramme donne tout.
- **La redondance est une preuve** : un flag qui ressort d'un vote majoritaire sur des dizaines de trames indépendantes ne doit rien au hasard.

Et le consensus a un nom — quatre mots soufflés pendant 90 secondes par un satellite qui se croyait discret : `STARPWN{Syn7h_v1be$_fr0m_0rb1t}` — validé sur la plateforme. Reconstruction par démodulation FSK/Doppler et vote majoritaire sur les trames HDLC répétées ; TLE (NORAD 25544 = ISS) confirmé comme leurre.